

IOCs, IOAs & TTPs

The indicator family

Type	What	Example	Half-life
IOC	Artefact of compromise	hash, C2 IP, registry key, filename	Days-weeks (attackers rotate)
IOA	Observable behavior	unusual child process, beaconing, admin-MSF entry	Even attackers change habits slow
TTP	Tactics, techniques, procedures	'uses PowerShell to download and execute from X'	Long-lived – the most stable

Why IOA beats IOC

A hash dies the moment a packer re-rolls. A *behavior* ('office spawning powershell'→network to a fresh domain) describes the attack *shape* that survives:

```
IOC-based rule:  file hashes of Cobalt Strike beacon variants  -> dies on rebuild
IOA-based rule:  parent=Word AND child=powershell AND child:network
                  -> catches variant generations
TTP-based:      technique T1059.001 detection, applies to ANY payload
```

Turning intel into detections

New sample arrives → analyze → extract BOTH IOC (hash, domain) and IOA (download cradle, MS office-parent)

Write: Sigma rule for the IOA (broader); YARA/static for the IOC family

Enrich with ATT&CK technique for the report mapping

Fade the IOC rule, keep the behavioral one

Confidence & false friends

Intelligence says IP X; SIEM shows 3 hits – but are they the same?
IOC without context (geo) → you've generated more noise
Always pair IOC with TTP: 'this domain is C2 *because* it's used with PowerShell-to-beacon payloads'

The mature detection stack hunts IOAs mapped to TTPs; IOCs are just the first-responder fingerprints.

[← The Intelligence Cycle](#)

[TTP Mapping with MITRE ATT&CK →](#)